PROBLEM STATEMENT

Does EPSS lead or follow a CISA KEV listing?

Why it isn't obvious

- EPSS v3 inputs may include public exploit code and KEV status itself.
- So a jump after listing is partly mechanical, not foresight (the TA's concern).
- The real test is whether scores separate before day 0.



Approach

1 **2024 KEV listings**
day 0 = date CISA added the CVE

2 **Matched never-listed twins**
same CVSS band, published ±30 days

3 **Event study (DiD)**
listed − twins vs. pre-period gap

Repo link : https://github.com/ryonahh/EPSS-Lead-or-Follow-

Implementation so far

186

KEV CVEs added in 2024

1 Jan – 31 Dec 2024

›

77

eligible listed CVEs

109 dropped: under 60 days of EPSS history

›

383

matched twins

same CVSS band, published ±30 d, seed 42

›

485

of 486 daily EPSS v3 files

2 Nov 2023 – 1 Mar 2025; 1 Dec 2024 missing

Analysis: rulebook rules, one extra filter disclosed

1 **Gap vs. baseline**

Listed EPSS − mean of its twins, day −60..+60, minus the gap over days −60..−31

2 **Lead-time rule**

First day before day 0 the gap stays above 2 SD of baseline noise for 3 days

3 **Threshold crossings**

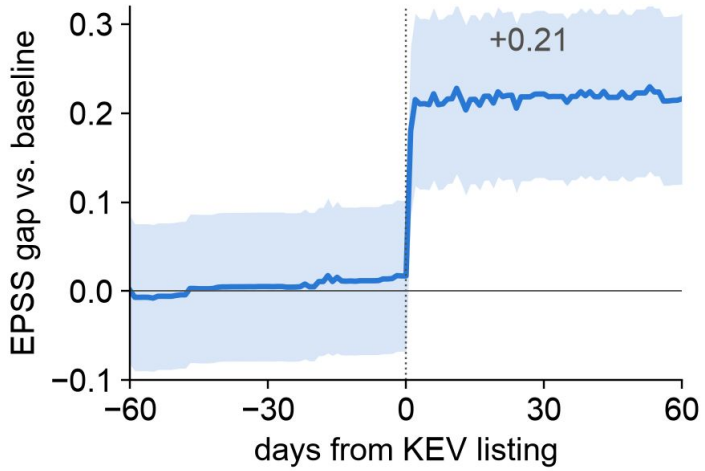
How many listed CVEs reach EPSS 1%, 10%, 50% before day 0

4 **Ingestion buffer**

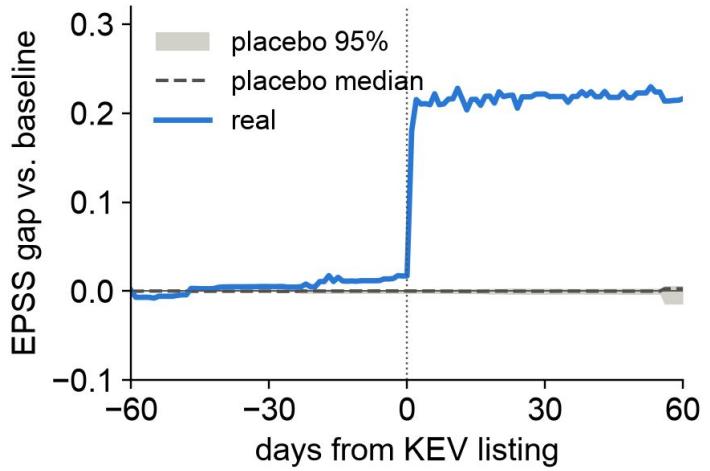
3, 7 and 14-day buffers set up; exploit-date split still pending

Results: EPSS follows the listing

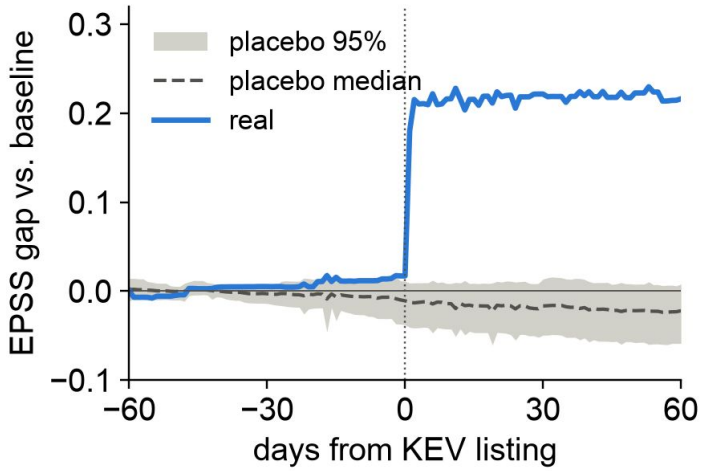
Main result: listed − twins (95% CI)



Placebo A: random twin plays "listed"



Placebo B: fake day 0, 1000 draws



EPSS ≥	Reached by day 0	At day −60
1%	40 / 77	38
10%	29 / 77	25
50%	20 / 77	18

Most were already above at day −60; few crossed upward. Placebo B: real pre-listing gap ranks in the top ~1–5% of draws, so a small early rise is not ruled out.

+0.21

jump after listing (CI 0.14–0.28). Expected if KEV-linked signals feed EPSS (documented for v3)

0.013

pre-listing gap, days −19.. −1 (CI −0.002–0.026): not distinguishable from zero

None

lead time claimed: the 2 SD rule fires in 16–59% of placebo draws

Remaining work

1. **Exploit-code split**
   better-dated sources than Exploit-DB (only 18 of 77 have a date)

2. **Confirm EPSS v3 dates**
   v3 ran 7 Mar 2023 – 17 Mar 2025, which covers our whole window

3. **Subgroups and limitations**
   CVSS band and vendor; 109 dropped fast-exploited CVEs

4. **Reproducibility and README**
   full rerun from raw files already matches (same pairs, same plot); finalize README

5. **Final report**
   merge sections, add placebo result and figures

The novelty gap

Separate what EPSS learns from its dated inputs from any genuinely early signal

Matched-control event study
listed CVEs vs. never-listed twins

+

Dated-input decomposition
when exploit code, KEV and other inputs appear

+

Input-only baseline
what EPSS would say from its inputs alone